

ESCUELA COLOMBIANA DE INGENIERÍA JULIO GARAVITO

SEGURIDAD Y PRIVACIDAD DE TI

ARQUITECTURA DE SEGURIDAD AWS

ENFOCADO EN

Análisis Caso Estudio

**ANDERSSON DAVID SÁNCHEZ MÉNDEZ
CRISTIAN SANTIAGO PEDRAZA RODRÍGUEZ**

PROFESOR:

JAVIER IVAN TOQUICA BARRERA

Lugar: Bogotá

Fecha: Febrero 20/2026



ARQUITECTURA DE SEGURIDAD AWS

Estudiante: Andersson David Sánchez Méndez

Estudiante: Cristian Santiago Pedraza Rodríguez

Enfocado en: Análisis Caso Estudio

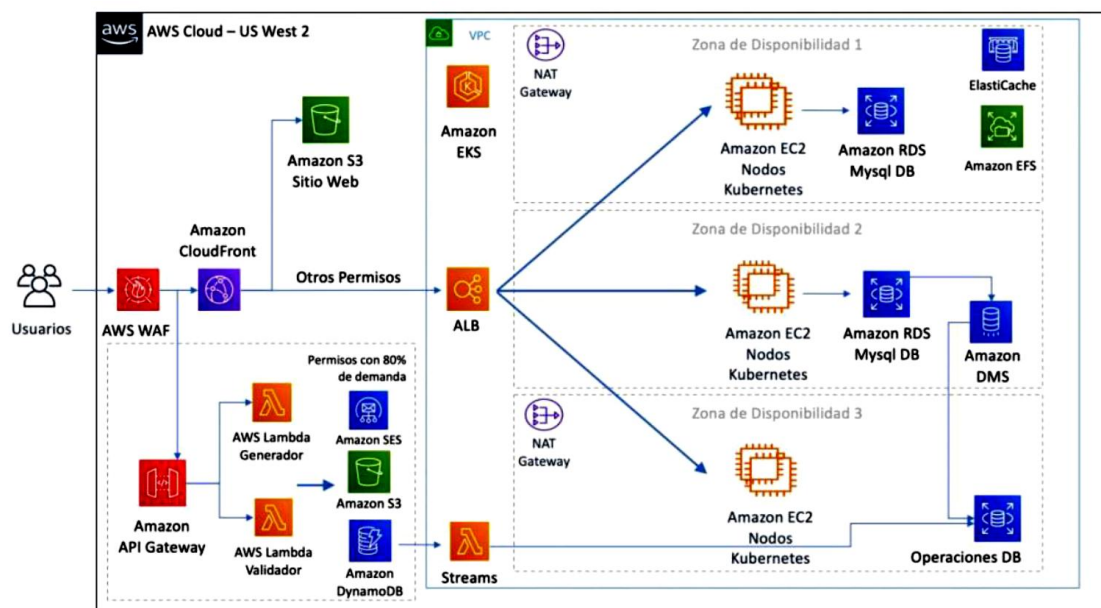
Fecha: Febrero 20, 2026

1. Introducción

Durante las últimas dos décadas el mundo de IT ha experimentado un cambio acelerado y constante de las tecnologías que nos permiten crear soluciones innovadoras, la mayoría de esos cambios han sido impulsados por la necesidad de lograr un “Time to market” más competitivo, así como, crear soluciones que con un alto grado de escalabilidad y resiliencia.

El objetivo de este taller es revisar un caso práctico en el cual una solución diseñada en un modelo tradicional, en su mayoría usando componentes infraestructura como servicio (IaaS) ha sido re – diseñada para utilizar componentes nativos del Cloud y posteriormente definir los controles de seguridad apropiados para preservar la Confidencialidad, Integridad y Disponibilidad de los datos.

Lectura: Evolucionando frente a una pandemia, cómo escalar para atender a todo un país usando tecnologías serverless en AWS | Blog de Amazon Web Services (AWS)



2. Preguntas.

Estudie el marco de referencia de seguridad de AWS (Ejemplos y prácticas recomendadas de arquitecturas de referencia (amazon.com)), específicamente la categoría Seguridad, identidad y cumplimiento determine 4 controles que deberían ser implementados en la arquitectura final mencionada en la lectura.

Para determinar los controles que deberían ser implementados como arquitectura final, damos un contexto sobre las lecturas y los enlaces de referencia.

1. Resumen y Contexto arquitectónico

La evolución de IaaS tradicional a componentes Serverless (AWS Lambda, API Gateway, DynamoDB) y contenedores orquestados (Amazon EKS) para plataformas de alto tráfico gubernamental (como el caso de la pandemia) rompe

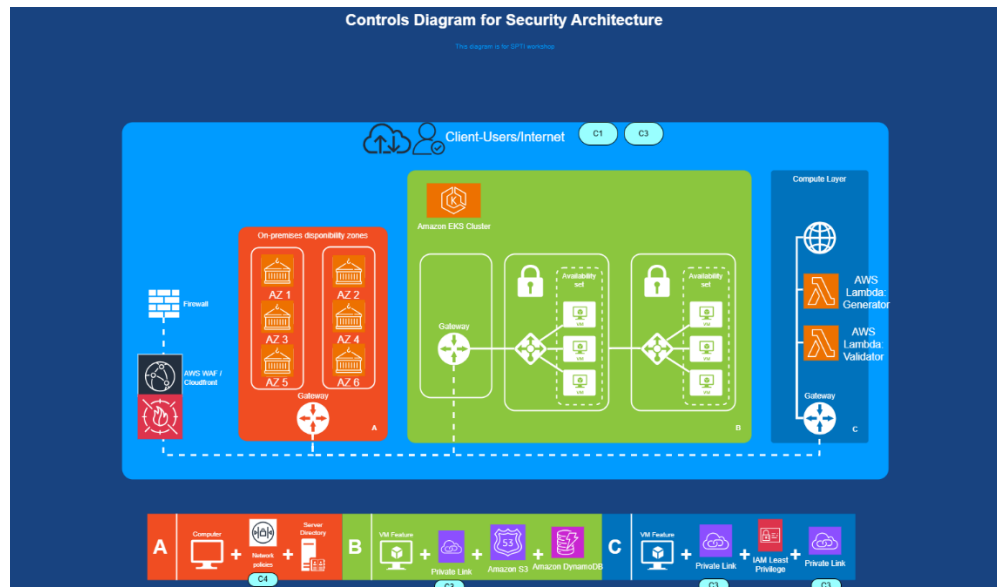
el perímetro de red clásico. En IaaS, el control recaía en Firewalls y Security Groups a nivel de red (Capa 3/4). En una arquitectura nativa Cloud, el perímetro de seguridad primario se desplaza hacia la Identidad (IAM) y la Capa de Aplicación (Capa 7).

Implementar Zero Trust Architecture (ZTA) en este entorno requiere abordar inhibidores comunes: la sobreautorización y la falta de microsegmentación que facilita el movimiento lateral de un atacante. De hecho, ZTA exige que los usuarios y entidades (como funciones Lambda o Pods) se verifiquen cada vez que intentan acceder a los recursos, no solo al inicio.

2. Diagrama con Controles Señalados

En el diagrama se evidencia todo el flujo para evidenciar los controles de seguridad en este caso de estudio, partiendo de:

- [C1] Ubicación: Entre "Usuarios" y "AWS WAF / API Gateway".
- [C2] Ubicación: Sobre las funciones "AWS Lambda (Generador/Validador)".
- [C3] Ubicación: Entre las Lambdas y "Amazon DynamoDB / Amazon S3".
- [C4] Ubicación: Dentro de "Amazon EKS Nodos Kubernetes" (Zonas de Disponibilidad 1, 2, 3, ...).



3. Definición Técnica de Controles (Arquitectura Nativa Cloud)

Control 1: Prevención de Abuso de APIs y Limitación de Tasa (Rate Limiting)

- Marcador: [C1]
- Servicio/Mecanismo AWS: AWS WAF asociado a Amazon API Gateway y Amazon CloudFront, junto con *Usage Plans* de API Gateway.
- Riesgo que mitiga: Ataques DDoS volumétricos y de capa de aplicación (Capa 7), fuerza bruta y agotamiento de recursos serverless (Billetera/Denegación de servicio financiero).
- Dimensión CIA: Disponibilidad.
- Justificación técnica: Al exponer endpoints serverless directamente a internet, el escalado automático de Lambda y API Gateway puede generar costos desbordados si es atacado. Implementar *Rate-based rules* en AWS WAF mitigará picos anómalos de IP individuales. Adicionalmente, configurar *Throttling* a nivel de etapa y método en API Gateway garantiza la

Disponibilidad de los servicios backend (Generador/Validador) al limitar el límite de concurrencia y los *bursts*, protegiendo la cuota regional de AWS.

Control 2: Políticas de Permisos Estrictos por Función (Microsegmentación IAM)

- Marcador: [C2]
- Servicio/Mecanismo AWS: AWS IAM (Execution Roles específicos por función Lambda) usando Resource-Based Policies.
- Riesgo que mitiga: Sobreautorización (Overauthorization) y escalamiento de privilegios de código comprometido.
- Dimensión CIA: Confidencialidad e Integridad.
- Justificación técnica: Un inhibidor clave de ZTA es que a las entidades se les otorga acceso que no necesitan, o no se les retira cuando cambia su función. En lugar de un rol IAM monolítico para todas las Lambdas, la "Lambda Validador" debe tener un rol IAM que permita *únicamente* `dynamodb:GetItem` sobre una tabla específica, mientras que la "Lambda Generador" debe tener permisos separados para `s3:PutObject`. Esto impone privilegios mínimos a nivel computacional y previene que una inyección de código en una función alcance recursos no autorizados.

Control 3: Tráfico Privado para Servicios Gestionados (VPC Endpoints)

- Marcador: [C3]
- Servicio/Mecanismo AWS: AWS PrivateLink (VPC Endpoints tipo Gateway para S3 y DynamoDB).
- Riesgo que mitiga: Exfiltración de datos, interceptación de tráfico e intentos de acceso desde el internet público o mediante credenciales robadas.
- Dimensión CIA: Confidencialidad.
- Justificación técnica: Dado que la arquitectura maneja información sensible de ciudadanos, el tráfico entre los VPCs (como los nodos de EKS o Lambdas dentro de la VPC) y los servicios como S3/DynamoDB no debe salir al Internet público atravesando un NAT Gateway. Implementar VPC Endpoints garantiza que los datos viajen exclusivamente por el *AWS Global Network*. Adicionalmente, permite adjuntar *Endpoint Policies* que restrinjan el acceso a las tablas o buckets *exclusivamente* si el origen es la VPC designada, fortaleciendo el perímetro lógico.

Control 4: Aislamiento de Red a Nivel de Contenedor (Kubernetes Network Policies)

- Marcador: [C4]
- Servicio/Mecanismo AWS: Kubernetes Network Policies mediante el complemento (add-on) de AWS VPC CNI / Calico en Amazon EKS.
- Riesgo que mitiga: Movimiento lateral intra-clúster.
- Dimensión CIA: Confidencialidad e Integridad.
- Justificación técnica: Limitar el acceso para cumplir con ZTA requiere segmentar redes para mapearlas a grupos de usuarios específicos (microsegmentación), previniendo el movimiento lateral. Si un atacante compromete un contenedor en EKS (ej. vulnerabilidad en una dependencia de Node/Python), un Security Group de la instancia EC2 no detendrá su avance hacia otros Pods en el mismo nodo o clúster. Las Network Policies actúan como un firewall a nivel de capa 3/4 dentro del clúster K8s, declarando explícitamente qué Pods pueden comunicarse entre sí por Ingress/Egress, y bloqueando el tráfico por defecto hacia las bases de datos RDS y el servicio interno de mensajería (Streams).

4. Tabla de los Controles

#	Servicio/Mecanismo AWS	Riesgo que Mitiga	Dimensión CIA	Foco / Principio Arquitectónico
C1	AWS WAF & API Gateway Throttling	DDoS de Capa 7, Fuerza Bruta, Denegación de Servicio Económica.	Disponibilidad	Protección perimetral de la capa de acceso a las APIs y mitigación de abusos.
C2	IAM Roles (Least Privilege) por Función Lambda	Sobreautorización de código, escalamiento de privilegios.	Confidencialidad, Integridad	Zero Trust: Identidad como nuevo perímetro. Microsegmentación de permisos.
C3	AWS PrivateLink (VPC Endpoints) para S3 y DynamoDB	Exfiltración de datos, enrutamiento inseguro, uso de credenciales robadas.	Confidencialidad	Aislamiento lógico del flujo de datos en el backbone privado de AWS.
C4	Kubernetes Network Policies (EKS)	Movimiento lateral de atacantes intra-clúster.	Confidencialidad, Integridad	Zero Trust: Microsegmentación estricta de contenedores y cargas de trabajo.

5. Conclusión Técnica

La migración de una arquitectura IaaS a una nativa Cloud (Serverless/EKS) exige rediseñar el modelo de amenazas. Mientras que en servidores tradicionales dependíamos de segmentación de VLANs y Firewalls perimetrales, en arquitecturas con AWS Lambda y Amazon API Gateway la postura de seguridad se debe abstraer hacia la capa de identidad (IAM) y las políticas de acceso a nivel de API. Al alinear los controles propuestos (WAF, PrivateLink, IAM restrictivo y Kubernetes Network Policies) con los preceptos de Zero Trust Architecture, neutralizamos de manera efectiva el movimiento lateral y la sobreautorización, mitigando vulnerabilidades fundamentales inherentes a sistemas de despliegue y escalado masivo e instantáneo.

REFERENCIAS

- Amazon Web Services. (2020). *Evolucionando frente a una pandemia, cómo escalar para atender a todo un país usando tecnologías serverless en AWS*. AWS Blog. Retrieved from <https://aws.amazon.com/es/blogs/aws-spanish/evolucionando-frente-a-una-pandemia-como-escalar-para-atender-a-todo-un-pais-usando-tecnologias-serverless-en-aws/>
- Amazon Web Services. (n.d.). *Ejemplos y prácticas recomendadas de arquitecturas de referencia*. AWS Architecture Center. Retrieved from https://aws.amazon.com/es/architecture/?cards-all.sort-by=item.additionalFields.sortDate&cards-all.sort-order=desc&awsf.content-type=*all&awsf.methodology=*all&awsf.tech-category=*all&awsf.industries=*all
- Amazon Web Services. (n.d.). *Seguridad, identidad y cumplimiento*. AWS Architecture Center. Retrieved from https://aws.amazon.com/es/architecture/security-identity-compliance/?achp_ftd1&cards-all.sort-by=item.additionalFields.sortDate&cards-all.sort-order=desc&awsf.content-type=*all&awsf.methodology=*all
- Amazon Web Services. (2023). *Security Pillar - AWS Well-Architected Framework*. AWS Whitepapers. Retrieved from <https://docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html>
- Ross, S. J. (2024). *The Inhibitors to Zero Trust Architecture*. ISACA Journal, Volume 3.